

Internal Security Audit: Controls and Compliance Assessment

Simulated Case Study — Botium Toys

Security Control Review

Audit Summary

Botium Toys' source risk assessment rates the organization's overall risk at **8 out of 10**, driven by gaps in asset management, security controls, and compliance practices. This internal review compares the safeguards currently in place with the controls and selected compliance considerations provided in the case materials.

The goal is to show where protections already exist, where gaps remain, and which improvements should be prioritized to reduce risk to customer data and business operations.

Control	Status
Least Privilege	Gap
Disaster recovery plans	Gap
Password policies	Gap
Separation of duties	Gap
Firewall	Implemented
Intrusion detection system (IDS)	Gap
Backups	Gap
Antivirus software	Implemented
Manual monitoring, maintenance, and intervention for legacy systems	Gap
Encryption	Gap
Password management system	Gap
Locks (offices, storefront, warehouse)	Implemented
Closed-circuit television (CCTV) surveillance	Implemented
Fire detection/prevention (fire alarm, sprinkler system, etc.)	Implemented

Selected Compliance Considerations

PCI DSS-Related Considerations

Consideration	Status
Access to cardholder data is restricted to authorized users	Gap
Cardholder data is handled and stored securely	Gap
Cardholder data is encrypted	Gap
Secure password management practices are in place	Gap

GDPR-Related Considerations

Consideration	Status
E.U. customer data is kept private and secure	Gap
A 72-hour breach-notification plan is in place	Met
Data is inventoried and classified	Gap
Privacy policies and procedures are documented and enforced	Met

SOC-Related Control Considerations

Consideration	Status
User access policies are established	Gap
Sensitive PII/SPII is kept confidential	Gap
Data integrity controls are in place	Met
Data access is limited to authorized users	Gap

Key Findings

- **Existing controls:** Firewall protection, antivirus software, physical locks, CCTV surveillance, and fire detection/prevention are already in place.
- **Access-control gaps:** Least privilege and separation of duties have not been implemented, leaving access to internal and customer data broader than necessary.
- **Resilience gaps:** The organization lacks critical-data backups and a disaster recovery plan, creating additional business-continuity risk if systems or data become unavailable.
- **Detection and protection gaps:** Intrusion detection, encryption, password management, and regularly scheduled maintenance for legacy systems need improvement.
- **Compliance-related gaps:** The PCI DSS-related review identified gaps across all selected practices. GDPR-related strengths include breach-notification planning and documented privacy procedures, while customer-data protection and classification remain weak. SOC-related observations show that data-integrity controls are present, but access and confidentiality controls need improvement.
- **Overall risk:** These findings are consistent with the source assessment's overall risk rating of **8 out of 10**.

Remediation Priorities

1. Protect sensitive access and data. Implement least privilege and separation of duties, introduce centralized password management, and encrypt cardholder and PII/SPII data.

2. Improve resilience and detection. Establish tested backups and a disaster recovery plan, add intrusion detection, and create a recurring maintenance schedule for legacy systems.

3. Strengthen asset and data management. Maintain the existing asset inventory and complete data classification so the organization knows what it owns, where sensitive information is stored, and which systems require the strongest protection.

These actions address the most significant weaknesses identified in the assessment and would reduce exposure to unauthorized access, data loss, undetected threats, and business disruption.